

SRC-0032 - Model-based security testing in IoT systems: A Rapid Review

Domanda standard 1/4 - Qual e il problema di ricerca e qual e il contributo?

Rapid Review, research questions, selezione ed evidenza

Identita	Lonetti, Bertolino e Di Giandomenico (2023), Information and Software Technology 164, 107326.
DOI	10.1016/j.infsof.2023.107326
PDF	SRC-0032-lonetti-bertolino-di-giandomenico-2023.pdf; SHA-256 beb812227d804747cbad12e9d4421d897068940ed49b63c4029f190b67f09de5
Metodo	Rapid Review: 803 pubblicazioni considerate, 17 studi primari inclusi.
Classificazione	model_required: la generazione inizia da un test model esplicito.

Problema

L eterogeneita di dispositivi, firmware, protocolli e contesti IoT rende costosa la progettazione manuale dei test di sicurezza. La fonte studia come modelli del SUT, proprieta di sicurezza e modelli di attacco siano usati per derivare test.

Sei domande

- Formalismi di modellazione.
- Obiettivi di testing.
- Tecniche di generazione ed esecuzione.
- Applicazioni e domini IoT.
- Attacchi coperti.
- Sfide, gap e direzioni future.

Selezione

667 record (2021) -> 16 inclusi dopo snowballing
116 nuovi record (2022) -> 1 incluso
corpus finale = 17

Contributo per DDTA

La review chiude il ramo model-based security testing e definisce il confine model-to-test. Non dimostra document-to-model automation.

Limiti del contributo

- Rapid Review, non full SLR.
- Scopus come unica base automatica.
- Nessun quality assessment degli studi.
- Orizzonte di ricerca: aprile 2022.

SRC-0032 - Model-based security testing in IoT systems: A Rapid Review

Domanda standard 2/4 - Quali sono gli artefatti iniziali e come vengono rappresentati?

Test model, security properties, attack model, criterion e proiezioni

Pipeline di input

```
requirements / specifications / SUT
-> security-enriched test model
+ attack model or threat template
+ test-selection criterion
-> abstract security tests
```

Formalismi principali

UML class diagram	7/17 studi; descrive entità e dipendenze.
UML + OCL	6 dei 7 studi UML; operazioni, parametri, pre/postcondizioni e comportamento atteso.
Timed automata	5/17; stati, transizioni, clock, vincoli e reachability.
Attack tree	4/17 come modello supplementare dell'attaccante.
Altri	CPN, BPMN, DFD, topology graph, MACM e Mealy machine appresa.

Modelli combinati

- System or behavior model.
- Security profile or property constraints.
- Attack tree, threat template or attack-surface model.
- Test purpose and coverage criterion.

Classificazione documentation-first

I requisiti e le specifiche possono alimentare la costruzione del modello, ma la fonte non valuta estrazione automatica da documentazione eterogenea. Serve un modello formale o semi-formale compatibile con la tecnica.

Proiezione neutrale DDTA

- Entità, componenti, operazioni, messaggi e protocolli.
- Stati, transizioni, clock e vincoli.
- Security requirements, protected properties e trust boundaries.
- Attacker actions, attack paths e deployment context.

SRC-0032 - Model-based security testing in IoT systems: A Rapid Review

Domanda standard 3/4 - Come funzionano traceability, change, automation e ruolo umano?

Da requisito a test astratto, concretizzazione, adapter, esecuzione e verdict

Catena evidenziale

```
security requirement
-> model property / constraint
-> attack model / threat template
-> selection criterion
-> abstract test
-> concrete test + adapter
-> execution environment
-> observed result
-> reviewed verdict
```

Automazione osservata

- OCL coverage e symbolic model exploration.
- Reachability, model checking e UPPAAL.
- Attack-tree path coverage e cost-prioritized vectors.
- Security test purposes.
- Model-guided fuzzing e penetration testing.
- TTCN-3 e altri artefatti di test.

Abstract vs executable

Abstract test	Implementation-independent sequence, tree or scenario derived from the model.
Concretization	Technology-specific values, calls and scripts.
Adapter	Maps abstract messages to SUT interfaces and responses back to the framework.
Oracle	Determines pass, fail, blocked or inconclusive meaning; no common taxonomy in the review.

Change

La rigenerazione dei test è possibile dopo una modifica del modello, ma context awareness, dynamic evolution, sincronizzazione e adapter maintenance restano problemi aperti.

Ruolo umano

- Costruzione e validazione del test model.
- Scelta delle proprietà, test purpose e attack model.
- Sviluppo di adapter e testbed.
- Validazione dell'oracle e interpretazione dei risultati.

SRC-0032 - Model-based security testing in IoT systems: A Rapid Review

Domanda standard 4/4 - Quali sono risultati, limiti e rapporto con DDTA/overlay?

Coverage, attacchi, domini, gap e contratto del plugin MBST

Risultati

Coverage	Oltre il 40% usa criteri di copertura; behavioral coverage non basta per tutti gli obiettivi security.
Verification	Quasi il 30% combina formal verification e MBST.
Formati	TTCN-3 circa 40%; compaiono XML, JUnit, C/C++ e Python.
Execution	TITAN e lo strumento più frequente; adapter necessari.
Domini	Automotive 3, smart cities 3, healthcare 1, smart home 1.

Attack evidence

DoS	8 studi
Eavesdropping	5
Dictionary / brute force	4 ciascuno
Key logger / social engineering / injection	3 ciascuno
Coverage complessiva	Circa 40% della tassonomia IoT adottata.

Disciplina

model coverage != attack coverage
passing suite != absence of vulnerabilities
model checking != test execution

Contratto plugin MBST

- Projection/schema e security properties richieste.
- Attack model, selection criterion e coverage semantics.
- Generator/version e abstract-test schema.
- Concretization, adapter, environment e oracle.
- Expected/observed result, provenance e review state.

Gap

Mancano derivazione governata del test model dai documenti, oracle validation, semantic-preserving concretization, sincronizzazione end-to-end e confronti realistici su larga scala.